

NARRATIVA EXPLICATIVA

Contexto, Propósito e Indicadores Clave de Encuesta Integral 2026

Versión: 1.0

Fecha: Enero 2026

Público: Directivos, Auditores, Stakeholders de Riesgo

INTRODUCCIÓN: LA REALIDAD ACTUAL DE CIBERSEGURIDAD EN ESPAÑA (2026)

El Panorama: Cifras Impactantes

A enero de 2026, organizaciones españolas enfrentan realidad desafiante:

- NIS2 en transición: Deadline septiembre 2025 ya pasado; 60% de entidades críticas aún en piloto
- Incidentes en alza: +75% de ataques globales YoY 2025 vs 2024 (Check Point)
- Vulnerabilidades explosivas: 27.000+ CVEs publicadas 2025 (vs 21.000 en 2024)
- Madurez dispersa: Solo 5% de organizaciones globales alcanzan Nivel 4+ en NIST CSF (Cisco 2024)
- Falsa confianza: 48% de CISOs consideran postura "adecuada" cuando menos de 13% realmente lo es (Commvault)

En este contexto, **esta encuesta existe para responder pregunta crítica:**

¿Qué tan preparada está realmente mi organización para amenazas cibernéticas contemporáneas?

No es pregunta de cumplimiento académico. Es pregunta de **viabilidad operativa y resiliencia**.

PARTE 1: POR QUÉ ESTA ENCUESTA, AHORA

1.1 La Trampa del "Cumplimiento de Caja"

Organizaciones españolas típicamente responden a regulación siguiendo patrón:

MODELO TRADICIONAL (Inefectivo):

1. Regulación (NIS2) llega
2. Auditoría externa realizada
3. "Checkbox compliance" documentado
4. Aprobación y olvido
5. Incidente ocurre → descubrimiento de gaps reales

Resultado: Control de riesgo teatral. Documentación bonita. Seguridad pobre.

Esta encuesta interrumpe ese patrón mediante:

MODELO BASADO EN MADUREZ (Efectivo):

1. Evaluación basal de capacidades REALES
2. Gap analysis: Actual vs Deseado vs Benchmark
3. Priorización basada en riesgo e impacto
4. Mejora continua documentada
5. Auditoría valida progreso real (no solo documentos)

1.2 Diferencia: Compliance vs Madurez

Aspecto	Compliance (Tradicional)	Madurez (Moderno)
Pregunta clave	¿Cumplimos con regulación?	¿Podemos realmente defendernos?
Métrica	Checkboxes ✓	Capacidades operativas
Evidencia	Documentos	Telemetría, logs, resultados reales
Horizonte	Momento en tiempo (auditoría)	Continuo
Valor	Defensa legal	Resiliencia real

PARTE 2: LOS SEIS DOMINIOS: POR QUÉ ESTOS

2.1 Dominio 1: GOBERNANZA Y RIESGO

¿Por qué importa?

Sin gobernanza eficaz, seguridad es tarea técnica aislada, no estrategia empresarial.

Indicadores clave evaluados:

- ¿CISO tiene voz en decisiones estratégicas o solo "parchea problemas"?
- ¿Existe política formal de gestión de riesgos o es ad-hoc?
- ¿Se evalúan riesgos de terceros o confianza ciega?

Por qué es crítica en España:

NIS2 explícitamente exige "gobernanza de ciberseguridad proporcional". Auditoría NIS2 verificará:

- Existencia de política documentada
- Participación de dirección en decisiones
- Evaluación de terceros formales

Ejemplo real:

Organización A: CISO depende de CTO, sin autoridad en decisiones
→ Vulnerability management débil (sin presupuesto)
→ Falso cumplimiento NIS2 (política existe, pero sin poder ejecutar)

Organización B: CISO reporta a CEO, participa en junta directiva
→ Vulnerability management fuerte (presupuesto garantizado)
→ Cumplimiento auténtico NIS2 (políticas se ejecutan)

RESULTADO: A tendrá "auditoría OK" pero B estará realmente segura

2.2 Dominio 2: GESTIÓN DE VULNERABILIDADES E IMPLEMENTACIÓN EPSS

¿Por qué es transformador EPSS?

Antes de EPSS (2024), gestión de vulnerabilidades era **simple pero ineficiente**:

Flujo Antiguo:

Escaneo → CVSS alto → Prioridad crítica → Reparación en 2 semanas
(Resultado: 80% del trabajo en vulnerabilidades que nunca fueron explotadas)

EPSS cambió paradigma:

Flujo Moderno:

Escaneo → EPSS+CVSS+KEV → Probabilidad real de ataque → Remediación inteligente
(Resultado: 50% reducción de trabajo, 8x mejor eficiencia)

Indicadores clave evaluados:

- ¿Está EPSS integrado en flujo de trabajo?
- ¿Cuál es cobertura de escaneo? (% del "attack surface")
- ¿Cuál es MTTR (media de tiempo a remediación) para críticas?

Por qué es crítica en España:

- INCIBE comenzó difusión de EPSS (2025)
- NIS2 requiere "priorización basada en riesgo" (EPSS es evidencia cuantificable)
- Budgets limitados — máximo ROI requiere máxima eficiencia (EPSS lo habilita)

Ejemplo de impacto real:

Empresa mediana española, 500 empleados:

Pre-EPSS: 2.000 CVEs activas, equipo remediación 20% utilización

Post-EPSS: 200 CVEs críticas priorizadas, equipo 95% utilización

Resultado: Misma inversión → 10x mejor cobertura de riesgo real

2.3 Dominio 3: PRUEBAS DE PENETRACIÓN

¿Por qué es más que "hackear a propósito"?

Penetration testing maduro es:

NO: "Contratar empresa, que haga pentesting, recibir reporte, guardar"

SÍ: "Programa continuo que simula adversarios reales, valida defensas, informa mejora de controles, mide eficacia de remediación"

Indicadores clave evaluados:

- ¿Con qué frecuencia? (annual vs continuous)
- ¿Cuál es cobertura? (¿incluye cloud, IoT, terceros?)
- ¿Se re-testean findings remediados?

Por qué es crítica en España:

- Sector público (ENS) exige pen testing periódico
- Sector crítico (NIS2) exige validación externa de controles
- Fraude interno requiere testing físico + social engineering

Indicador de madurez:

Nivel 1 (Débil): Pen test anual "porque lo pide regulación"

Nivel 5 (Maduro): Red team continuo + validación que remediación real ocurrió
+ aprendizaje en cultura de seguridad

2.4 Dominio 4: MONITOREO DE SEGURIDAD (SIEM)

¿Por qué SIEM es corazón operacional?

Sin visibilidad centralizada de eventos de seguridad:

Situación: Atacante en red durante 200 días antes de descubrimiento

Causa: No había SIEM, logs dispersos en 50 sistemas diferentes

Costo: €3M en remediación, demanda regulatoria, pérdida de datos clientes

Con SIEM maduro:

Situación: Atacante detectado en 4 horas

Causa: SIEM capturó patrones anómalos de movimiento lateral

Costo: €50K en respuesta + incremento en detección

Beneficio: Prevención de breach masivo

Indicadores clave evaluados:

- ¿Cuánta infraestructura está cubierta?
- ¿MTTD (Mean Time to Detect)? ¿Horas, días o meses?
- ¿Tasa de falsos positivos? (¿80% ruido o 20%?)

Por qué es crítica en España:

- GDPR requiere "medidas de detección" (Art 32)
- NIS2 requiere "monitoreo de seguridad en tiempo real"
- Incidentes recientes (2024-2025) en español orgs muestran MTTD lamentable

2.5 Dominio 5: RESPUESTA A INCIDENTES

¿Por qué no es suficiente "tener un plan"?

Realidad 2025: 92% de organizaciones tienen plan de respuesta a incidentes
13% lo han probado realmente
5% tienen respuesta 24/7 operativa

Plan papelado ≠ Respuesta eficaz.

Indicadores clave evaluados:

- ¿Plan existe, probado, comunicado?
- ¿Hay capacidad 24/7/365?
- ¿Cuál es MTTE (Mean Time To Escalate) a dirección/reguladores?

Por qué es crítica en España:

NIS2 Art 19 exige:

- Notificación a autoridades dentro **24 horas** (vs 72 antes)
- Plan de respuesta documentado y testeado
- Roles y responsabilidades definidas

Incumplimiento = Multa de 2% facturación + responsabilidad personal de directivos

Ejemplo de diferencia:

Org A (Débil): Incidente detectado, 72 horas hasta aviso a regulador
Multa: 2% facturación anual

Org B (Madura): Incidente detectado, 2 horas hasta aviso a regulador
Bonus regulatorio: "Rápida notificación demuestra cumplimiento"

2.6 Dominio 6: CAPACITACIÓN Y CONCIENCIA DE SEGURIDAD

¿Por qué el "eslabón humano" es el más débil?

Estadísticas 2025:

- 90% de breaches tienen componente humano (phishing, credential reuse)
- 60% de empleados harían clic en phishing obvio
- 5% de empleados reportan phishing voluntariamente

Indicadores clave evaluados:

- ¿Programa formal de capacitación existe?
- ¿Qué % completó capacitación? (Compliance rate)
- ¿Qué % reporta phishing? (Behavioral change)

Por qué es crítica en España:

- GDPR + NIS2 requieren capacitación documentada
- Auditoría externa valida participación + cambio de comportamiento (no solo "vimos vídeo")
- ROI de capacitación es 3-4x superior a herramientas: €1 en capacitación evita €3-4 en breach

Ejemplo transformador:

Org A (Débil):

- Capacitación obligatoria anual (1 video genérico)
- Tasa de click en phishing: 35%
- Tasa de reporte: 2%

Resultado: Defensas débiles

Org B (Madura):

- Capacitación multi-canal (e-learning, simulaciones, micro-learning)
- Phishing mensual
- Gamificación de reportes
- Tasa de click: 8%
- Tasa de reporte: 25%

Resultado: Primera línea de defensa funcional

PARTE 3: INDICADORES CLAVE (KPIs) POR DOMINIO

3.1 Gobernanza y Riesgo

KPI	Métrica	Target	Significado
CISO Autonomía	Reporte directo a CEO/Junta	Sí	Influencia estratégica
Política Formal	Política documentada + vigente	Sí	Framework de decisiones
Evaluación Terceros	% de terceros evaluados formalmente	>80%	Supply chain risk managed
Revisión Política	Frecuencia de revisión	Anual/Semestral	Adaptación a amenazas

3.2 Gestión Vulnerabilidades

KPI	Métrica	Target	Significado
Cobertura Escaneo	% attack surface escaneado	>80%	Visibilidad de riesgos
Adopción EPSS	% CVEs con EPSS score	>90%	Priorización basada en riesgo
MTTR Críticas	Días promedio remediación críticas	<7 días	Exposición limitada
Validación Remediación	% re-scans confirmados	>80%	Verificación de cierre
Eficiencia Operacional	CVEs activas promedio/mes	<500	Gestión manejable

3.3 Pruebas Penetración

KPI	Métrica	Target	Significado
Cadencia PT	Frecuencia mínima	Trimestral	Evaluación regular
Cobertura PT	% superficies probadas	>70%	Evaluación completa
Validez Hallazgos	% hallazgos válidos	>85%	Precisión diagnóstica
Remediación PT	MTTR hallazgos críticos	<30 días	Cierre efectivo

3.4 Monitoreo SIEM

KPI	Métrica	Target	Significado
Cobertura Logs	% infraestructura cubiertas	>70%	Visibilidad de eventos
Capacidad Detección	# reglas activas	>500	Coverage amenazas
MTTD	Tiempo promedio a detección	<24 horas	Rapidez de detección
Falsos Positivos	% alertas que son FP	<40%	Calidad de detección
Automatización	% incidentes manejados automáticamente	>30%	Eficiencia operativa

3.5 Respuesta Incidentes

KPI	Métrica	Target	Significado
Plan IR Formal	Plan documentado + probado	Sí	Preparación operativa
Capacidad 24/7	Disponibilidad respuesta 24/7	Sí	Cobertura continua
MTTE	Tiempo escalación reguladores	<24 horas	Cumplimiento NIS2
PIR Formal	% incidentes con revisión formal	>80%	Lecciones aprendidas

3.6 Capacitación Seguridad

KPI	Métrica	Target	Significado
Tasa Cumplimiento	% empleados completaron	>85%	Cobertura programa
Phishing Susceptibility	% click rate simulaciones	<15%	Comportamiento defensivo
Reporte Phishing	% phishing reportados	>20%	Cultura de reporte
Capacitación Especializada	Formación por rol alto-riesgo	Sí	Profundidad apropiada

PARTE 4: MAPEO REGULATORIO - ESPAÑA 2026

4.1 Alineación NIS2

Requisito NIS2	Dominio Encuesta Evaluado	KPI Clave
Art 21(E): Gestión Vulnerabilidades	GV	MTTR, Cobertura
Art 19: Respuesta Incidentes 24h	RI	MTTE, Capacidad 24/7
Artículos 21-22: Criptografía	GV, SI	Evaluación técnica
Art 18: Divulgación responsable	GR, RI	Política formal + SLA

4.2 Alineación ENS (Administración Pública)

Control ENS	Dominio Encuesta	Evidencia
SD.05: Gestión Vulnerabilidades	GV	Política, proceso, SLA
SF.01: Detección Ataques	SI	MTTD, cobertura logs
SP.01: Conciencia Seguridad	CC	Tasa cumplimiento, phishing rate

4.3 Alineación GDPR (Privacidad de Datos)

Artículo GDPR	Dominio Encuesta	Evidencia
Art 32: Medidas Técnicas	GV, SI, PT	Controles implementados
Art 32: Capacitación Personal	CC	Plan formación documentado
Art 34: Notificación Incidentes	RI	MTTE regulador

PARTE 5: CASOS DE USO REALES (FICTICIOS PERO REALISTAS)

Caso 1: Startup Tech (50 empleados)

PERFIL:

- Sector: Software as a Service (SaaS)
- Clientes: Principalmente pequeñas empresas españolas
- Regulación aplicable: GDPR (clientes confían datos personales)
- Presupuesto cybersec: €80K anuales

RESULTADOS ENCUESTA (Pre):

- GR: 2.0 (política básica, sin revisión formal)
- GV: 1.8 (escaneos ocasionales, sin EPSS)
- PT: 1.5 (sin pruebas formales)
- SI: 2.2 (logs pero sin correlación)
- RI: 2.1 (plan existe pero no probado)
- CC: 2.3 (capacitación anual obligatoria)
- IGM: 1.95 (Crítica)

RECOMENDACIONES RÁPIDAS (Q1):

1. Implementar EPSS en herramienta VM (€0, solo integración)
 - Impacto: -40% CVEs priorizadas, MTTR mejora 60%
2. Formalizá política de respuesta incidentes + tabletop (€5K)
 - Impacto: Capacidad 24/7 básica, MTTE <24h
3. Phishing mensual simulado (€2K/año)
 - Impacto: Comportamiento defensivo, reporte +10%

PROYECCIÓN POST-MEJORA (6 meses):

IGM: 2.8 → Aceptable (bajo Sí, pero mejorada 40%)

INVERSIÓN TOTAL: €7K

BENEFICIO: Reducción de riesgo GDPR, confianza cliente, insurance claims mejor

Caso 2: Banco Regional Español (5.000 empleados)

PERFIL:

- Sector: Banca
- Regulación: NIS2 (sector crítico), GDPR, PCI-DSS
- Presupuesto cybersec: €3.5M anuales
- Estado actual: Programa maduro, gaps específicos

RESULTADOS ENCUESTA (Pre):

- GR: 3.5 (CISO en junta, política annual review)
- GV: 3.2 (EPSS piloto, MTTR 14 días)
- PT: 3.8 (pen test trimestral + red team)
- SI: 3.4 (SIEM 80% cobertura, MTTD 8 horas)
- RI: 3.6 (plan probado, 24/7 SOC)
- CC: 3.1 (capacitación anual + phishing mensual)
- IGM: 3.43 (Buena)

BRECHA IDENTIFICADA:

- NIS2 requiere 4.0+ en sector crítico
- Gap: 0.57 puntos (16% mejora requerida)

INICIATIVAS PRIORITARIAS (12 meses):

1. Ampliar EPSS a 100% CVEs (vs 40% actual)
2. Implementar IA/ML en SIEM (mejorar MTTD a <2 horas)
3. Red team continuo + simulation ejercicios
4. Automatización de remediación via SOAR

PROYECCIÓN POST-MEJORA:

IGM: 3.43 → 4.1 (Excelente, cumple NIS2 sector crítico)

INVERSIÓN: €800K (herramientas + personal especializado)

BENEFICIO: Cumplimiento NIS2 auténtico, multa evitada €70M potenciales

CONCLUSIÓN: PROPÓSITO FINAL

Esta encuesta existe para transformar pregunta abstracta:

"¿Estamos seguros?"

En preguntas concretas y respondibles:

- ¿Qué % de nuestra superficie de ataque está visible?
- ¿Cuánto tiempo tarda detectar incidente?
- ¿Cuánto tiempo tarda remediación?
- ¿Confían empleados reportar phishing?
- ¿Existe realmente capacidad respuesta 24/7?

Y finalmente:

¿Ante ataque real, resistiríamos?

Esa es la pregunta que importa. Esta encuesta responde.

*Narrativa desarrollada por Consorcio de Científicos de Datos y Estrategas de Ciberseguridad
Enero 2026*